

MORAA GemVision

Work Audit Log · Phase 6 Compliance and Cleanup · generated 2026-10-02

How to use this page: tick the box ☐ at the start of a task once you have checked that it is done and done well. Write the status (done, in progress, blocked, not started) by hand in the empty box at the right of each task, and fill in the summary table below. Nothing on this page is pre-filled with a status. The reasons, decisions (D1, D2...) and errors (E1, E2...) are explained once for the whole phase, after the checklist; tasks refer to them by number.

Domain	Tasks	Done	In progress	Blocked	Not started
1. Privacy	3				
2. Tax and billing	2				
3. Cost and limits	4				
4. Cleanup and not done	4				
Total	13				

Why this phase

The business collects customers' names, GST numbers, addresses and product photos and sends photos to AI providers abroad, with no notice, no consent, no way to delete data, no retention limit, a receipt titled 'Tax Invoice' without tax fields, no record of what the AI costs, and team orders that bypass every limit. Indian data-protection rules (DPDP Act) and tax rules expect better, and the owner needs to see AI spending. This phase builds the mechanisms; the wording and periods that need the owner or a lawyer stay switched off until supplied.

WHAT WAS DONE, IN SHORT

A consent step before any personal data is collected, a retention job and a DELETE MY DATA command (both careful to keep money records), a receipt that says what it is plus an IGST option, a per-call AI cost log with a daily spend alert, a separate ceiling for team orders, and validation of Meta's media links. Small cleanups removed empty folders.

Checklist

1. Privacy

Customers know what is kept, agree to it, and can have it removed.

- ☐ **1.1 No personal data is collected from a number until it has agreed to the current notice (switched off until the notice text is supplied)**

FILES backend/app/services/consent_service.py, backend/app/models/consent_record.py, backend/alembic/versions/0018_consent_records.py

HOW TO CHECK Set CONSENT_REQUIRED=true and CONSENT_NOTICE_TEXT on a test number, send HI: the notice with an 'I agree' button arrives and nothing else happens until you tap it.

- ☐ **1.2 A customer can send DELETE MY DATA and CONFIRM DELETE to remove photos and personal details while the money trail is kept; an administrator can do the same by script**

FILES backend/app/services/data_lifecycle.py, backend/scripts/erase_customer.py

HOW TO CHECK On a test customer with zero balance send the two messages: reply confirms; their name shows as Deleted customer and their ledger rows are unchanged. A customer with money in the wallet is refused.

- ☐ **1.3 Old customer photos and phone numbers in audit notes are removed on a schedule (switched off until approved)**
- FILES backend/app/services/data_lifecycle.py
- HOW TO CHECK Tests in tests/test_data_lifecycle.py. RETENTION_ENABLED stays false until you approve the periods.
-

2. Tax and billing

- ☐ **2.1 The local PDF says 'Payment receipt' and that it is not a GST tax invoice**
- FILES backend/app/services/invoice_service.py
- HOW TO CHECK Recharge on a test number with ERPNext off: the PDF title reads PAYMENT RECEIPT.
-
- ☐ **2.2 An inter-state buyer's ERPNext invoice uses the IGST template and the right place of supply (inactive until two settings are filled)**
- FILES backend/app/services/gst_places.py, backend/app/services/erpnext_service.py
- HOW TO CHECK Tests in tests/test_billing_erpnext.py use a fake ERPNext. Not tried against your real ERPNext.
-

3. Cost and limits

- ☐ **3.1 Team (admin) orders have their own daily ceiling instead of bypassing every limit**
- FILES backend/app/ai/image_generation_manager.py, backend/app/services/meta_whatsapp_service.py
- HOW TO CHECK Set MAX_ADMIN_GENERATIONS_PER_DAY to 6 and send two Packs from a team number: the second is refused with 'Team daily image limit reached'.
-
- ☐ **3.2 Every AI call is recorded with an estimated cost, a daily spend alert can warn the owner, and a report lists the last week**
- FILES backend/app/services/provider_call_log.py, backend/scripts/cost_report.py, backend/alembic/versions/0019_provider_calls.py
- HOW TO CHECK After migration 0019, run python scripts/cost_report.py: one row per day and provider. Costs read 0 until you set the price per call.
-
- ☐ **3.3 The photo download link must be on Meta's own hosts and the media id must be a plain token**
- FILES backend/app/services/meta_whatsapp_service.py
- HOW TO CHECK Tests in tests/test_media_hardening.py.
-
- ☐ **3.4 An optional rule that team ops commands must start with the word 'ops'**
- FILES backend/app/services/ops_forward.py
- HOW TO CHECK Off by default. With OPS_EXPLICIT_PREFIX=true a team 'start' goes to the customer flow and 'ops start' goes to ops.
-

4. Cleanup and not done

- ☐ **4.1 Empty placeholder folders removed; the generated load-test results file is no longer tracked**
- FILES ai-engine/, shared/, backend/.gitignore
- HOW TO CHECK git status no longer shows last_results.json changing after a load test.
-

☐	4.2 Split the two very large files and merge duplicate generation code (MAINT-1, ARC-4, ARC-5)	
	DROPPED - this task is no longer being done.	
☐	4.3 Merge the seven earring prompt routes (MAINT-2)	
	DROPPED - this task is no longer being done.	
☐	4.4 A real GST verification provider and verified-only GSTIN on invoices (EXT-8)	
	BLOCKED BY The owner's decision to buy a verification service or remove the step.	

Key decisions and why

D1 Build consent, retention and erasure switched OFF (or confirmation-gated) until the owner supplies wording and periods.

WHY THIS CHOICE

The notice text is a legal statement and retention deletes photos; neither should be invented by an engineer. The mechanisms are ready and tested.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Write a default privacy notice** — not chosen because: Legal wording the owner or their adviser must own.
- **Turn retention on with the audit's suggested periods** — not chosen because: Irreversible deletion of customer photos without the owner's approval.

Relates to task(s): 1.1, 1.2

D2 Erasure keeps the customer row (placeholder name, phone and details) because the wallet ledger points at it, and refuses while money remains.

WHY THIS CHOICE

Tax and audit rules require the money trail to stay; deleting the row would break the ledger. A customer with money left needs a person to settle it.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Delete the customer row entirely** — not chosen because: Breaks the wallet ledger and the payment records that must be kept.
- **Refund the balance automatically** — not chosen because: Refund policy for leaving customers is the owner's decision.

Relates to task(s): 1.2

D3 Retitle the fallback PDF 'Payment receipt' instead of trying to make it a legal tax invoice.

WHY THIS CHOICE

A real tax invoice needs the seller's GST details and tax rows that live in ERPNext; a receipt that does not claim to be one is honest and safe.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Add GST fields to the local PDF** — not chosen because: Duplicates ERPNext's job and risks wrong tax figures.

Relates to task(s): 2.1

D4 Do not merge the seven earring prompt routes or split the two large files now.

WHY THIS CHOICE

Five of the route files are frozen by the prompt freeze guard, and the large files are patched by name in hundreds of tests and carry every money path. The risk is higher than the benefit before launch.

OTHER OPTIONS CONSIDERED (AND WHY NOT)

- **Refactor now** — not chosen because: Would unlock frozen files and touch every payment path without the owner's say.

Relates to task(s): 4.1

Errors faced

E1 AssertionError: ['COST_PER_CALL_GEMINI_RUPEES', 'COST_PER_CALL_OPENAI_RUPEES'] unused settings

Cause: The price lookup built the setting name from the provider name, so the settings looked unused.

Fix: An explicit table of the two prices.

Task: 3.2

E2 git: docker/.env.example was not in the commit

Cause: The repository ignores every .env* file, including the example file.

Fix: Renamed it env.example and updated the instructions.

Task: 4.2